

Lab Session 1: Vulnerability Scanning and Web App Recon

Date: 6 June 2026

Duration: 50 mins

Scenario:

*Your Company's new internal web application is going live next week. You are tasked with a pre-launch security review of the dev server (**http://localhost or a DVWA install**) to identify exposed files, header issues and known CVEs.*

Objective:

Use Nikto to scan a web server for known vulnerabilities , misconfigurations and outdated software. Use Gobuster to brute-force hidden directories and files that are not publicly linked.

Environment:

Kali IP: 192.168.56.1/24

Target IP: 192.168.56.105

Subnet: 192.168.56.0/24

Tools Used: Nikto and Gobuster

Virtual Machines Running: Metasploitable 2 VM on Virtual Box

Commands, step by step:

1. `sudo /etc/init.d/apache2 start`
2. `sudo /etc/init.d/mysql start`
3. `nikto -h http://192.168.56.105`
4. `nikto -h https://192.168.56.105 -ssl`

5. gobuster dir -u <http://192.168.56.105/dvwa> -w
</usr/share/wordlists/dirb/common.txt>

Findings:

- ❖ ***nikto -h <http://192.168.56.10>*** The target server presents a severe security risk due to critically outdated software and insecure configurations open on Port 80. The deployment of Apache 2.2.8 (High Risk) and an End-of-Life version of PHP 5.2.4 (Critical Risk) exposes the system to numerous publicly known CVEs and remote code execution vulnerabilities. Additionally, having WebDAV enabled (High Risk) creates a significant attack vector, as unauthorized users can exploit this extension to launch malicious file upload attacks. Immediate software upgrades and configuration hardening are required. Revealed 30 open ports. Ftp, ssh and http were among them, these are ports that are usually targeted by attackers for network exploit and reconnaissance.
- ❖ ***nikto -h <https://192.168.56.105> -ssl*** The HTTPS scan targeting port 443 failed at the SSL handshake stage, confirming that Metasploitable 2 lacks a functional HTTPS/SSL configuration. This absence of encryption poses a high risk to the environment, as unencrypted plaintext transmission makes the server vulnerable to network eavesdropping and Man-in-the-Middle (MitM) attacks.
- ❖ ***gobuster dir -u <http://192.168.56.105/dvwa> -w
</usr/share/wordlists/dirb/common.txt>*** The Gobuster directory brute-force scan against the /dvwa path revealed several critical security exposures. The most severe findings include an exposed and unauthenticated /setup page, which allows arbitrary database resets, and an accessible /config directory that may contain sensitive credentials. Additionally, the server exposes internal configurations via /phpinfo, and hosts a restricted .htpasswd file that could compromise credentials if file permissions are ever misconfigured.

What an Attacker Could Do With This Information

- Exploit outdated Apache/PHP versions using known CVEs from public vulnerability databases
- Use WebDAV PUT method to upload a web shell and gain remote code execution

- Access phpMyAdmin to dump, modify or delete the database
- Use the /config directory to retrieve database credentials
- Intercept unencrypted HTTP traffic using a MitM attack (no HTTPS)
- Brute force the login page using Hydra, having confirmed it exists via Gobuster

Lessons Learned

- Always start services from the correct VM — Apache and MySQL on Metasploitable, tools on Kali
- Ping confirming localhost is alive does not mean a web service is running
- Nikto and Gobuster complement each other — Nikto finds vulnerabilities, Gobuster finds hidden paths
- An HTTPS error is itself a finding, not just a failed scan
- Status 302 redirects still confirm a resource exists, even if access requires authentication
- Use | tee filename.txt or -o filename.txt to save scan output for documentation going forward

Note to Self:

Remember when doing Vulnerability Scanning and Web app Recon, always power on your VM, that's your listening in device without it your local host will not connect.

Also DVWA on the VM and not on the terminal

What's Next?

Password Auditing and Hash Cracking using John the Ripper and Hydra